

CASE STUDY

DESIGNING A SECURE BLOCKCHAIN-BASED SUPPLY CHAIN MANAGEMENT SYSTEM

Name: Adhithyan S

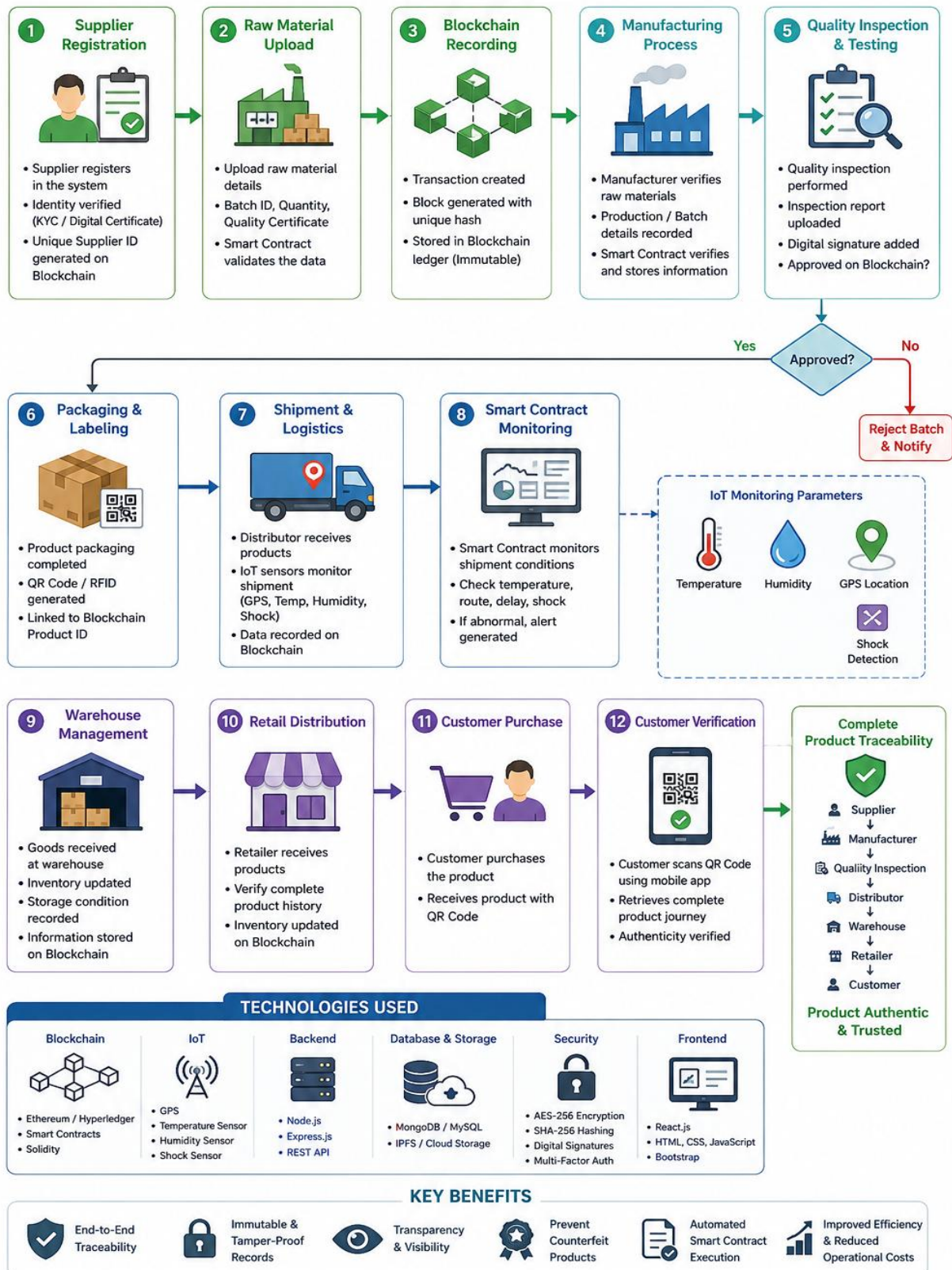
Reg No: 192421102

Course Code: CSA5803

Course: DEVSECOPS ENGINEERING AND APPLICATION SECURITY

1. SECURE WORKFLOW MAPPING

SECURE BLOCKCHAIN-BASED SUPPLY CHAIN MANAGEMENT SYSTEM COMPLETE WORKFLOW



1. Supplier Registration

- The process begins with the supplier registering in the system.
- The supplier's identity is verified using Know Your Customer (KYC) procedures or Digital Certificates.
- Once verified, the blockchain network generates a unique Supplier ID.
- This ensures that only authorized suppliers can participate in the supply chain.

2. Raw Material Upload

- The registered supplier uploads information about the raw materials, including:
 - Batch ID
 - Quantity
 - Quality Certificate
- A smart contract automatically validates the uploaded information.
- If the data is valid, it proceeds to the blockchain.

3. Blockchain Recording

- After successful validation, a new blockchain transaction is created.
- The transaction is encrypted and assigned a unique cryptographic hash.
- The information is permanently stored in the blockchain ledger.
- Since blockchain records are immutable, the data cannot be altered or deleted.

4. Manufacturing Process

- The manufacturer receives the verified raw materials.
- Before production begins, the manufacturer checks the blockchain to confirm the authenticity of the materials.
- Production details such as:
 - Product ID
 - Batch Number
 - Manufacturing Date
 - Machine Used

- are recorded.
- Smart contracts verify these records before they are stored on the blockchain.

5. Quality Inspection and Testing

- After manufacturing, products undergo quality inspection.
- Inspectors upload:
 - Inspection reports
 - Test results
 - Digital signatures
- The system checks whether the product meets quality standards.

Decision Point:

- **Approved:** The product proceeds to packaging.
- **Rejected:** The batch is rejected, and the manufacturer is notified.

This prevents defective products from entering the market.

6. Packaging and Labeling

- Approved products are packaged.
- A QR Code or RFID tag is generated for each product.
- The QR code is linked to the blockchain transaction.
- This enables complete product traceability throughout the supply chain.

7. Shipment and Logistics

- The packaged product is handed over to the distributor.
- During transportation, IoT sensors continuously monitor:
 - GPS Location
 - Temperature
 - Humidity
 - Shock or Vibration
- These sensor readings are periodically recorded on the blockchain.

8. Smart Contract Monitoring

- Smart contracts automatically monitor transportation conditions.
- They compare sensor readings with predefined thresholds.

If all conditions remain normal:

- Shipment continues.

If abnormalities occur, such as:

- Excessive temperature
- Route deviation
- Package damage
- Shipment delay

the system immediately generates an alert to the logistics manager for corrective action.

9. Warehouse Management

- Products arriving at the warehouse are scanned.
- Warehouse personnel update:
 - Inventory status
 - Storage conditions
 - Entry and Exit times
- These updates are securely stored on the blockchain, maintaining accurate inventory records.

10. Retail Distribution

- Retailers receive the products from the warehouse.
- Before accepting them, the retailer verifies the complete blockchain history.
- This ensures that only authentic products reach retail shelves.

11. Customer Purchase

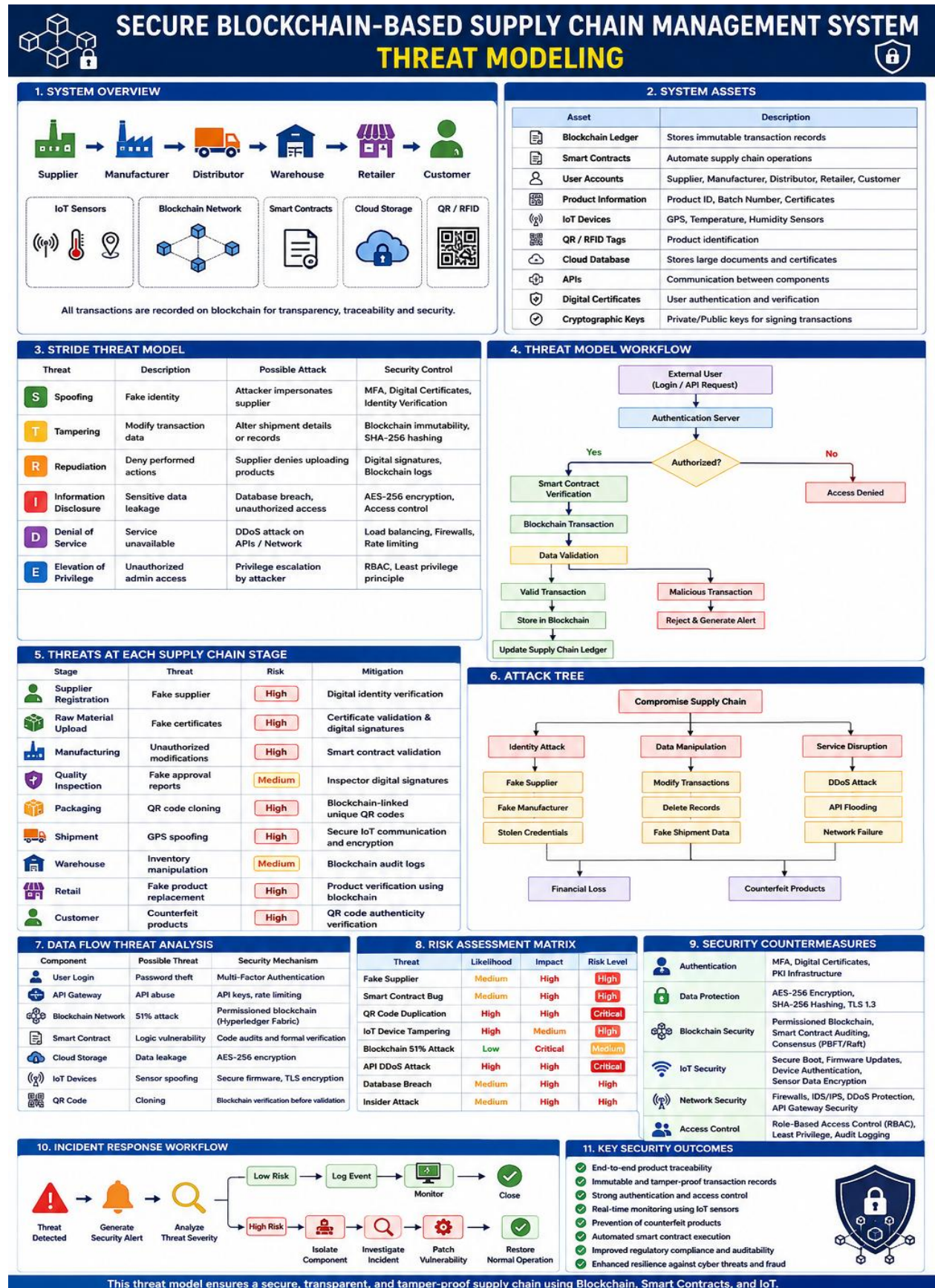
- Customers purchase products that contain the QR code generated during packaging.
- The QR code serves as the product's digital identity.

12. Customer Verification

- Customers scan the QR code using a mobile application.
- The blockchain instantly displays the complete product history, including:
 - Supplier
 - Manufacturer
 - Quality Inspection
 - Distributor
 - Warehouse
 - Retailer

If all records are valid, the customer receives confirmation that the product is genuine.

2. THREAT MODELING



1. System Overview

The supply chain begins with the Supplier, who provides raw materials to the Manufacturer. The products are then transported through the Distributor, stored in the Warehouse, delivered to the Retailer, and finally purchased by the Customer. Throughout this process, IoT sensors, smart contracts, cloud storage, and QR/RFID technologies work together with the blockchain network to record every transaction securely. This provides end-to-end traceability and prevents unauthorized modifications.

2. System Assets

The system protects several critical assets, including the blockchain ledger, smart contracts, user accounts, product information, IoT devices, QR/RFID tags, cloud database, APIs, and cryptographic keys. These assets are essential because they store sensitive business data and ensure secure communication among all participants.

3. STRIDE Threat Model

The diagram applies the **STRIDE** framework to classify common cybersecurity threats:

- **Spoofing:** Attackers impersonate legitimate users, such as fake suppliers. This is prevented using Multi-Factor Authentication (MFA) and digital certificates.
- **Tampering:** Attempts to modify shipment or product information are prevented through blockchain immutability and SHA-256 hashing.
- **Repudiation:** Users cannot deny their actions because every transaction is digitally signed and permanently stored on the blockchain.
- **Information Disclosure:** Sensitive information is protected using AES-256 encryption and access control mechanisms.
- **Denial of Service (DoS):** Firewalls, load balancing, and rate limiting help prevent attackers from making the system unavailable.
- **Elevation of Privilege:** Role-Based Access Control (RBAC) ensures users can only access resources based on their assigned roles.

4. Threat Model Workflow

When a user sends a login or API request, the authentication server verifies the user's identity. If authentication is successful, the smart contract validates the transaction before it is stored on the blockchain. If an unauthorized or malicious request is detected, the system rejects the transaction and generates a security alert, preventing unauthorized access and maintaining data integrity.

5. Threats Across the Supply Chain

Each stage of the supply chain faces different security risks. Supplier registration may face fake identity attacks, manufacturing may experience unauthorized modifications, packaging can be targeted through QR code cloning, shipment data may be manipulated using GPS spoofing, and retailers or customers may encounter counterfeit products. These threats are mitigated through

digital signatures, smart contracts, blockchain verification, encrypted IoT communication, and unique QR codes.

6. Attack Tree

The attack tree illustrates possible attack paths. Attackers may attempt identity attacks by using stolen credentials, data manipulation by modifying blockchain records or shipment information, or service disruption through DDoS attacks and API flooding. These attacks can lead to financial losses, counterfeit products, and operational failures if appropriate security measures are not implemented.

7. Data Flow Threat Analysis

The system analyzes threats at every component. User accounts are protected with MFA, APIs use authentication keys and rate limiting, blockchain transactions are secured through permissioned consensus mechanisms, IoT devices communicate using encrypted channels, and QR codes are verified against blockchain records to prevent cloning.

8. Risk Assessment Matrix

The risk assessment evaluates each threat based on likelihood and impact. High-risk threats include QR code duplication, IoT device tampering, smart contract vulnerabilities, database breaches, and API DDoS attacks. This analysis helps prioritize security controls for the most critical threats.

9. Security Countermeasures

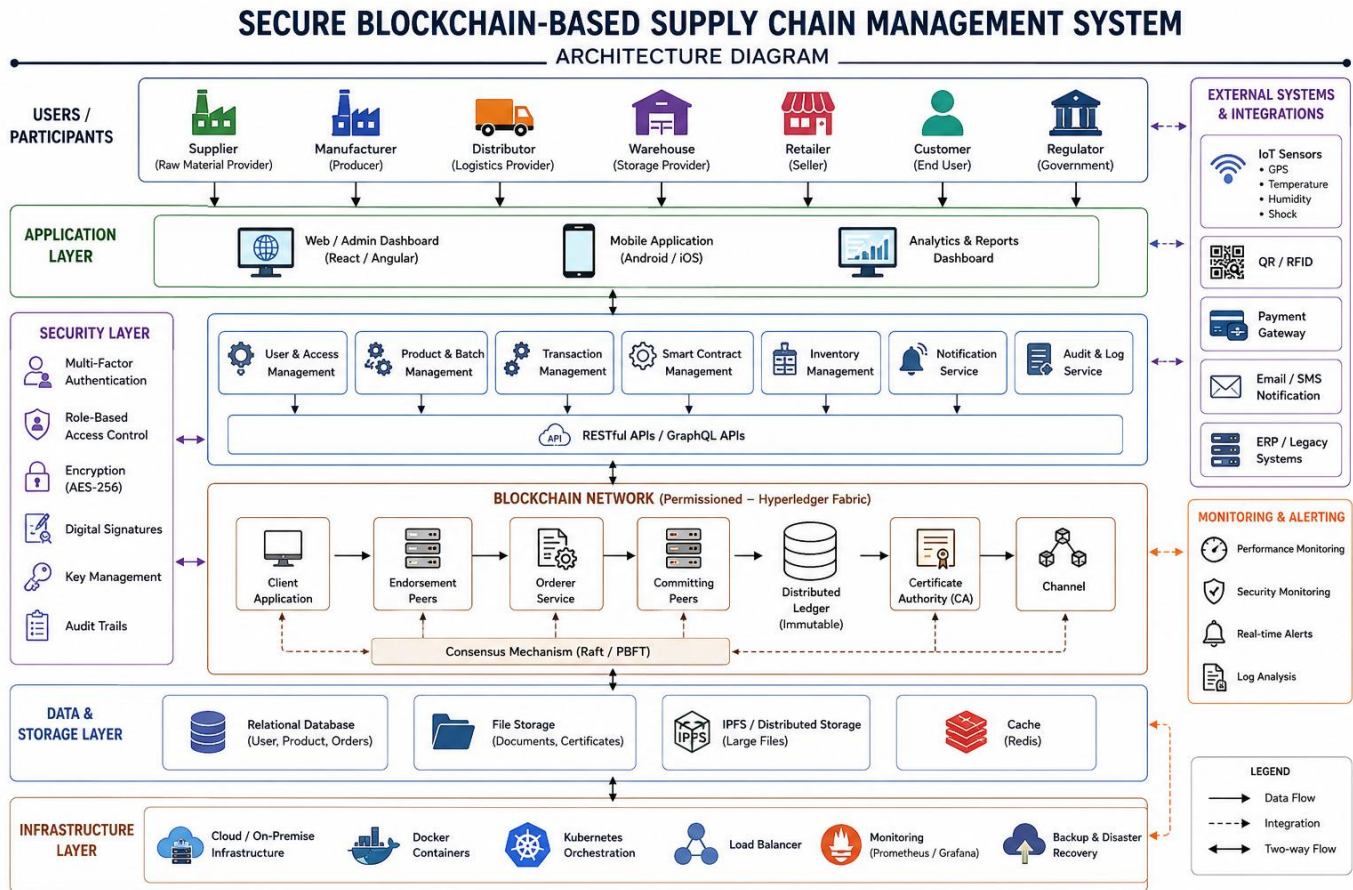
The diagram incorporates multiple layers of security, including:

- Multi-Factor Authentication and Public Key Infrastructure (PKI) for user authentication.
- AES-256 encryption, SHA-256 hashing, and TLS 1.3 for data protection.
- Permissioned blockchain and audited smart contracts for secure transaction processing.
- Secure IoT devices with firmware updates and encrypted communication.
- Firewalls, Intrusion Detection Systems (IDS), and API security to protect the network.
- Role-Based Access Control (RBAC) and audit logging to enforce authorization.

10. Incident Response Workflow

If a threat is detected, the system generates a security alert and analyzes its severity. Low-risk incidents are logged and monitored, while high-risk incidents trigger isolation of affected components, investigation, vulnerability patching, and restoration of normal operations. This process minimizes downtime and limits the impact of cyberattacks.

3. ARCHITECTURE DIAGRAM



The architecture diagram illustrates the overall design of the **Secure Blockchain-Based Supply Chain Management System**. It demonstrates how different users, applications, blockchain components, databases, and security mechanisms work together to provide a secure, transparent, and traceable supply chain.

1. Users / Participants Layer

The top layer consists of all stakeholders involved in the supply chain, including the Supplier, Manufacturer, Distributor, Warehouse, Retailer, Customer, and Regulator. Each participant performs specific tasks such as registering products, manufacturing goods, managing logistics, storing inventory, selling products, verifying authenticity, and monitoring regulatory compliance.

2. Application Layer

The application layer provides user interfaces for interacting with the system. It includes a Web/Admin Dashboard for suppliers, manufacturers, warehouses, retailers, and regulators to manage products,

inventory, and transactions. A Mobile Application allows distributors and customers to track shipments and verify products using QR codes. An Analytics Dashboard displays reports, transaction history, inventory status, and supply chain performance.

3. Security Layer

This layer protects the system against unauthorized access and cyber threats. It uses Multi-Factor Authentication (MFA) to verify user identities, Role-Based Access Control (RBAC) to restrict permissions based on user roles, AES-256 encryption to secure sensitive information, Digital Signatures to verify transaction authenticity, and Audit Trails to record all activities for accountability and compliance.

4. Business Logic Layer

The business logic layer manages the core operations of the supply chain. It includes modules for User and Access Management, Product & Batch Management, Transaction Management, Smart Contract Management, Inventory Management, Notification Services, and Audit Logging. These modules communicate through RESTful or GraphQL APIs, enabling seamless interaction between the applications and the blockchain network.

5. Blockchain Network Layer

The blockchain layer is the core of the architecture and is implemented using a permissioned Hyperledger Fabric network. User requests are processed through the Client Application, validated by Endorsement Peers, ordered by the Ordering Service, and committed to the Distributed Ledger by Committing Peers. The Certificate Authority (CA) manages digital identities and certificates, while the Consensus Mechanism (Raft/PBFT) ensures that only verified transactions are permanently stored, providing tamper-proof and transparent records.

6. Data & Storage Layer

This layer stores both structured and unstructured data. A Relational Database manages user accounts, product information, and inventory details. File Storage stores documents such as certificates and inspection reports, while IPFS (InterPlanetary File System) securely stores large files in a decentralized manner. Redis Cache improves system performance by providing faster access to frequently used data.

7. Infrastructure Layer

The infrastructure layer provides the computing environment required to run the application. It supports deployment on Cloud or On-Premise Infrastructure and uses Docker Containers and Kubernetes for containerization and orchestration. A Load Balancer distributes incoming requests efficiently, while Prometheus and Grafana monitor system performance. Backup and disaster recovery mechanisms ensure high availability and data protection.

8. External Systems and Monitoring

The system integrates with external technologies such as IoT sensors for monitoring GPS location, temperature, humidity, and shock during transportation. QR/Rfid tags enable product identification and traceability, while Payment Gateways, Email/SMS Notification Services, and ERP Systems enhance business operations. A dedicated monitoring module continuously tracks system health, analyzes logs, and generates real-time security alerts.

Conclusion

The architecture integrates blockchain, smart contracts, IoT, cloud computing, secure APIs, and advanced security mechanisms to build a reliable supply chain management platform. Each layer has a specific responsibility, from user interaction and business logic to secure transaction processing and data storage. Together, these components provide end-to-end product traceability, enhanced security, real-time monitoring, transparency, and protection against counterfeit products, making the system efficient, scalable, and trustworthy.